

x402 Allocation Readiness Audit — v0.2

Version-stamped snapshot: This audit is based on the x402 documentation and repository as of **2026-09-07**, with incremental evidence added **2026-09-13** (specification v2, all nine published extensions, three payment schemes, TSC.md, and the Technical Charter; repository tree fully enumerated at 3,919 paths). The protocol evolves quickly; conclusions expire with the snapshot. We invite corrections — see Contributing (../README.md#contributing).

Ray R • Independent Researcher • v0.2 • 2026-10-04

Layer: payment execution (value transfer). This audit asks one question of x402: when value flows through the protocol, does it carry any rule for how that value is *divided* among the parties that produced it — humans, agents, data providers, models, infrastructure? Attribution (who paid, who executed) is well addressed; allocation is the gap. We do not rank x402 against authorization-layer protocols (e.g. AP2): different layers, separate audits (see Appendix A for the layered mapping).

1. What x402 claims (verbatim)

Each claim below is quoted verbatim with source and snapshot date. Where a claim says nothing about value allocation, that silence is itself a finding.

#	Official claim (verbatim)	Source	What it addresses
X1	"x402 is an open, neutral standard for internet-native payments."	x402.org, snapshot 2026-09-07	Standard's openness and neutrality
X2	"Zero protocol fees — x402 is free for the customer and the merchant —just pay nominal payment network fees"	x402.org, snapshot 2026-09-07	Cost structure at protocol level
X3	"Zero restrictions — x402 is a neutral standard, not tied to any specific network"	x402.org, snapshot 2026-09-07	Network neutrality
X4	" Trust minimizing: all payment schemes must not allow for the facilitator or resource server to move funds, other than in accordance with client intentions"	GitHub README (Principles), main HEAD, snapshot 2026-09-07	Fund safety during execution
X5	" Network, token, and currency agnostic: we welcome contributions that add support for new networks (both crypto and fiat), signing standards, or schemes"	GitHub README (Principles), main HEAD, snapshot 2026-09-07	Multi-party technical compatibility
X6	" facilitator: A server that facilitates verification and execution of payments for one or many networks."	GitHub README (Terms), main HEAD, snapshot 2026-09-07	Role definition
X7	"Do not assume the public x402.org facilitator is the default production path for mainnet EVM routes."	GitHub README (Choosing a Production Path), main HEAD, snapshot 2026-09-07	Facilitator plurality
X8	"The facilitator does not hold funds or act as a custodian - it performs verification and execution of onchain transactions based on signed payloads provided by clients."	docs.x402.org/core-concepts/facilitator, snapshot 2026-09-07	Fund custody boundary
X9	"The first 1,000 onchain Facilitator transactions each month are free, then each additional onchain	docs.cdp.coinbase.com/x402/seller/facilitator (Coinbase Developer Platform), snapshot 2026-09-07, re-verified verbatim 2026-09-20	Facilitator-layer pricing

	transaction costs \$0.001. ... Facilitator fees are based on onchain activity, not payment requests. Payment verification is always free."		(commercial, public)
X10	"The Offer and Receipt Extension adds server-side signatures to x402, enabling: 1. Signed offers: the resource server can cryptographically commit to the payment terms it presents in <code>accepts[]</code> . 2. Signed receipts: after successful payment and service delivery, the resource server can return a signed receipt confirming the transaction." — and, on use cases: "This extension supports downstream use cases including: - dispute evidence and auditability, - user-review attestations (e.g., "I paid and received service"), - verifiable proof of commercial interactions for reputation systems." — and, on stability: "This extension is specified as an optional, composable addition to x402." / "Wire shape and field placement are not considered stable and may change to align with x402 canonical extension architecture once standardized."	specs/extensions/extension-offer-and-receipt.md, snapshot 2026-09-13 (first committed 2026-07-23)	Signed commercial evidence at execution layer
X11	" Out of Scope: This specification does not include: ... - Client-side budget management - Session handling mechanisms"	specs/x402-specification-v2.md, snapshot 2026-09-13	Declared scope boundary of the core spec
X12	"in the upto scheme, the amount field in <code>paymentRequirements</code> represents the maximum authorized amount at verification time, but the actual amount to settle at settlement time"	specs/x402-specification-v2.md, snapshot 2026-09-13	Amount-bound authorization primitive
X13	"An <code>assetTransferMethod</code> identifies how value is authorized or moved for a mechanism (a scheme on a specific network) — for example <code>eip3009</code> vs <code>permit2</code> on EVM exact"	specs/x402-specification-v2.md, snapshot 2026-09-13	Fund-transfer mechanics

2. Evidence check

#	Claim	Evidence status	Notes
X2	Zero protocol fees	Verifiable, now with two independently checkable layers	Protocol layer: no fee is charged by the standard itself. Facilitator layer: pricing is public and commercial — the Coinbase Developer Platform facilitator

			charges \$0.001 per onchain transaction after 1,000 free per month, with verification always free (X9). Fees exist but are transparent, capped per-transaction, and avoidable entirely (self-facilitation is a documented path, X7).
X4	Trust minimizing	Verifiable by design at execution layer	Payment schemes (exact, upto, batch-settlement — GitHub README, snapshot 2026-09-07; scheme specifications reviewed at snapshot 2026-09-13) are specified so facilitators cannot move funds beyond client intent; the facilitator "does not hold funds or act as a custodian" (X8). upto adds an explicit amount cap at verification time (X12). This is fund safety during transfer, not a rule for dividing produced value.
X5, X7	Network-agnostic; facilitator plurality	Verifiable	Multi-chain SDKs are shipped in the reference repository; running your own facilitator or self-facilitating inside the resource server is a documented production

			path. This is strong evidence the execution layer has no single mandatory chokepoint.									
X1	Open, neutral standard	Largely verifiable as of the 2026-09-13 snapshot; one residual gap	x402 is a Linux Foundation project ("Copyright © x402 a Series of LF Projects, LLC" — x402.org footer, snapshot 2026-09-07). Governance evidence added at snapshot 2026-09-13: the Technical Charter (adopted March 31, 2026) establishes the project as "x402 a Series of LF Projects, LLC", and TSC.md names the three Participating Organizations and their representatives: "	Coinbase, Inc.	Erik Reppel	", "	Cloudflare, Inc.	Rohin Lohe	", "	Stripe, Inc.	Steve Kaliski	"
X10	Signed offers/receipts	Verifiable, with a stated stability caveat	The extension provides server-side signatures covering offer terms and delivery									

			receipts, explicitly including "dispute evidence and auditability" as a use case. It is user-invisible in one respect: the signatures are the resource server's, and the extension does not carry user-intent authorization (see Appendix A for what the authorization layer looks like). Stability is self-declared as optional and not wire-stable (X10).
—	Allocation rule	Absent by inspection	Across the claims above, the core specification v2, all nine published extensions, and the three payment schemes reviewed at snapshot 2026-09-13, no mechanism defines how the value transferred should be split among contributing parties. No allocation constraint type, no value-split extension, no revenue-division primitive appears in the reviewed material.

3. ARL assessment (allocation dimension)

Classification rule (from the methodology): a system is classified **by the first question it fails**, not forced onto the nearest rank.

x402, in the value-allocation dimension: ARL 0.

- **ARL 0** — "No allocation rule exists; value is captured by whoever controls the interface"

- Basis: x402 defines who *pays* and who *executes* (client → resource server, via facilitator), and defines this well. It defines nothing about how value produced jointly by humans, agents, data, models, and infrastructure should be *divided*. With no allocation rule, the division defaults to whoever controls the interface (resource server pricing, facilitator fee-setting) — precisely the ARL 0 condition.

Read this correctly. ARL 0 on allocation is not a verdict that x402 fails at its own job. As a payment *execution* layer, x402 is genuinely strong: fund safety by design (X4, X12), no single mandatory facilitator (X7), multi-network reach (X5), signed commercial evidence emerging (X10), verifiable on-chain settlement volume (see §5

for what that volume does and does not evidence). The finding is scoping, not condemnation:

****x402 answers "who pays whom" and leaves "who deserves what share" to layers it does not govern.**** That residual question is what this project tracks.

4. Gap list (what would raise the allocation-dimension level)

Gap	To reach	Description
G1	ARL 1 (rule exists)	Any normative allocation rule or primitive: a value-split scheme, an allocation constraint type, a revenue-division extension point in the spec. Currently absent (scoped to reviewed material, snapshot 2026-09-13).
G2	Facilitator-layer economics	Closed for the incumbent facilitator (public CDP pricing, X9); open for the ecosystem: whether a market of facilitators with divergent fee structures emerges, and whether fee-setting remains verifiable as the ecosystem scales.
G3	ARL 2→3	If an allocation rule is added: it must be independently verifiable and usable by heterogeneous parties (human sellers, agent operators, data licensors) — not a single operator's private ledger.
G4	Governance evidence	Partially closed at snapshot 2026-09-13 (and we note this closure follows from widening our own review scope — the charter and TSC.md both predate the earlier 2026-09-07 snapshot): the Technical Charter and the named three-organization TSC make governance structure independently checkable. Residual: the complete Participating Organizations roster the charter references (§3.e, "the Project's governance repository") and admission-process details remain not independently checkable from documents we have reviewed.

5. Ecosystem reality check: settlement authenticity (case study)

Agentic commerce — AI agents paying for APIs, data, and compute autonomously — has been declared "arrived" based on headline metrics: 160+ million settlements on the x402 protocol, backed by Coinbase, Cloudflare, Google, Stripe and Visa under Linux Foundation governance.

Population-scale measurement tells a different story. The first academic audit

(arXiv:2607.12575, July 2026 — Ling et al., population-scale measurement of x402 on Base) found that of 136.7M settlements (\$44.1M) on Base over 280 days:

- 21.20% are provably fictitious;
- 63.78% are internal settlement within linked clusters (self-dealing);
- genuinely independent demand is bounded between \$187,861 and \$20,258,746 — a 100x uncertainty interval that no current infrastructure can narrow.

Settlement count, the ecosystem's headline metric, measures *manufacturability*, not adoption: gas is sponsored, nothing on-chain marks who controls a payment, and a manufactured settlement is indistinguishable from genuine demand at the single-transfer level.

Security research compounds the gap. The first systematic study of 15 real-world facilitators (USENIX Security 2026, covering 60K sellers / 360K buyers) demonstrates four novel attack vectors: Free Shopping, Asset Theft, Service Denial, and Gas Abuse. Meanwhile price integrity fails independently of fraud — 4.4% of 4,251 catalogued routes quote a live price that differs

from the listed price, with tail cases off by 100-1000x (TOLL-402 price-integrity study, August 2026).

Why this matters beyond crypto

Agentic commerce is inheriting the internet's trust infrastructure from scratch — without the consumer protection layer that took decades to build around card payments. Journalists and legal analysts (Forbes, Bloomberg Law, Mondaq, August 2026) have already flagged the chargeback liability gap: when an AI agent buys the wrong thing, no one can prove who authorized what. The x402 case demonstrates a pattern this project has documented across the AI economy: **adoption metrics that cannot be manufactured are the precondition for trustworthy ecosystems — and they do not yet exist here.**

What independent audit infrastructure would look like (research agenda)

1. Reproducible authenticity scoring (payment-graph clustering + cohort signals, per arXiv:2607.12575's method, as open tooling rather than a one-off paper);
2. Facilitator security benchmarking (extending x402scope's attack taxonomy);
3. Price-integrity monitoring (catalogued vs. live quote drift, per TOLL-402);
4. Agent reputation audit bridging ERC-8004 registries to independent verification.

This section will be updated as this project's related open-source work progresses.

Orthogonal replication check (September 2026)

As a first step toward open audit infrastructure, we replicated the population-scale methodology from an orthogonal direction and extended it, on the Tektonic x402 CCo public dataset (BigQuery, Analytics Hub). The public listing returns 52,723,702 raw settlement rows; filtering to our 105-address facilitator registry retains 52,652,290 settlements (99.86%), over the listing's full coverage window 2025-12-05 to 2026-04-14 UTC (131 days). The upstream listing stopped updating in April 2026, so every number in this section describes a frozen window, not today's network. As in the upstream note, every figure below is a share of this audited slice, never of x402: Solana-side settlement is not covered, the 105-address registry is a hand-assembled scope condition rather than ground truth, and facilitator-side internal traffic (routing, retries, batching) is indistinguishable from customer traffic in the raw events.

Findings (aggregate statistics only; full addresses withheld; our companion note — Zenodo DOI 10.5281/zenodo.22807288 — reports the headline bound; the full parameter grid, sensitivity analysis, and CCo replication files ship with the final report):

- **Concentration confirmed on an independent pipeline.** Across payer-level totals in the slice, the Gini coefficient is **0.974 for settled value and 0.967 for settlement count** — two different measurements, reported together so neither label drifts. Both are near the theoretical maximum.
- **Coordinated payer cohorts dominate count, not value.** Behavioral fingerprinting with union-find clustering — using no funding graph at all, an approach orthogonal to the paper's funding-provenance method — identifies 181 coordinated payer cohorts covering 52,008 of 78,196 payer addresses (66.5%). These cohorts account for **at most 84.1% of settlement count at the primary cutoff (fingerprint merge threshold ≥ 3 wallets; cohort cutoff ≥ 50 wallets)** (84.1–85.1% across the reported cutoff grid; 74.3–74.4% at the widest) **but only 24.9% of settled value.** The mean settlement across the slice is \$0.170: settlement count is the cheapest of the standard metrics to manufacture.
- **Orthogonal methods converge.** Ling et al. (arXiv:2607.12575, 2026-07-14) report 84.98% of Base settlement count as operator-internal; our behavioral-fingerprint bound is 84.1%, measured on a slice that is 38.5% of their census by count and ~20% by value. The

fingerprinting and clustering are our own and use no funding graph — we did not use their data or code — but both analyses rest on the same underlying evidence (Base on-chain events), so this is convergence of methods, not fully independent replication.

- **Relation to concurrent industry measurement.** TRM Labs (Hodge, 2026-09-09, trmlabs.com/trm-tech-blog/whos-actually-paying-measuring-ai-agent-payments-onchain) report roughly USD 52.7 million across 198.9 million settlement transactions through known x402 facilitators since May 2025 across Base, Solana, and Polygon; after removing self-payments, bulk flows, and thin-buyer sellers, they bound the share that appears agentic at 0.6%-7.5% of the remaining USD 25.62 million. We did not use their data or code, and the methods differ (their screens plus agency bounds; our behavioral fingerprints on a frozen CCo BigQuery window). Two cautions: the near-coincidence of headline figures — their USD 52.7 million of value vs our 52,652,290 settlements — is a coincidence of units and windows, not a cross-validation; and our audited slice is narrower than their population (105-address registry, 131-day window, no Solana side). The directional findings agree: both measurements conclude that headline settlement volume overstates genuine, consumption-driven demand.

Appendix A. Layered mapping: the authorization layer (AP2) and the execution layer (x402)

Self-contained section. Snapshot 2026-09-13 (AP2 repository [google-agentic-commerce/AP2](https://github.com/google-agentic-commerce/AP2), main HEAD `e1ea56db72a6385bce3e5c1112b3a56ce60acb43`; specification.md titled "Agentic Payment Protocol (vo.2)"). This appendix maps layers; it does **not** rank across them.

Why a mapping and not a ranking. AP2 and x402 occupy different layers and describe themselves accordingly. AP2 self-describes as: "The Agentic Payment Protocol (AP2) provides a protocol to secure Agent-performed payment transactions" (specification.md, snapshot 2026-09-13), and states: "AP2 operates as a security feature within a Commerce Protocol. The exact details of the Commerce Protocol ... are outside the scope of AP2. AP2 is designed explicitly to be compatible with the Universal Commerce Protocol (UCP) and integrates seamlessly." (specification.md). It is also "agnostic to the particular payment instrument used" — payment execution is left to the integrated party. x402, conversely, executes payments and declares "Client-side budget management" out of scope (X11). Authorization intent collection is likewise outside AP2's scope: "The Checkout and Payment Mandate contents are assembled by the Shopping Agent after it has determined what task the user wishes it to perform. The exact details of how this is achieved is outside of the scope of this specification." (specification.md). **Complementarity is therefore not an editorial analogy: each specification scopes itself that way — AP2 leaves payment execution to the integrated party, and x402 declares client-side budget management out of scope.**

What AP2 adds that x402 does not have. Three verbatim-anchored points:

1. **Authorization credentials.** "Mandates are the core means that AP2 uses to authorize agents." AP2 defines Checkout and Payment Mandates with a constraint enumeration (allowed payee, allowed payment instrument, amount range, budget, recurrence, and others; docs/ap2/payment_mandate.md). x402's v2 specification contains no mandate concept (zero grep hits in the reviewed files); its only adjacent primitive is the upto amount cap (X12), with no payee, purpose, or credential constraint.
2. **A human-consent anchor.** "The Trusted Surface role is a UI surface that is trusted to get informed user consent for an Intent before creating a user-signed Mandate", and

"The following role MUST be non-agentic: - Trusted Surface" (specification.md). x402 has no corresponding role or non-agentic requirement.

3. **A credential chain for disputes.** "In the case of a dispute, the Checkout Mandate and Receipt, and Payment Mandate and Receipt can be brought together to provide a non-repudiable picture of the transaction. Specific details of how this is used for dispute resolution, retention, and retrieval requirements are outside of the scope of this specification." x402's Offer and Receipt extension (X10) reaches the same dispute-evidence use case with server-side signatures, but those signatures carry no user-intent authorization, form no chain, and are self-declared not wire-stable. What x402 does that AP2 does not: it moves value (AP2 is agnostic to the payment instrument and delegates execution), with upto bounding the amount at verification time.

What the mapping does not establish. Integration between the two protocols is documented only at the documentation and sample layer, in one direction, in the future tense: the AP2 FAQ answers "Does this work with x402 standard for crypto payments?" by describing AP2 as payment-agnostic and pointing to a separate repository (google-agentic-commerce/a2a-x402) as "an implementation of A2A in conjunction with the x402 standard," adding "We will be aligning this closely with AP2 over time to make it easy to compose solutions which include all payment methods, including stablecoins." The AP2 specification and README do not mention x402 (zero grep hits in the reviewed files), and x402's reviewed materials do not mention AP2 (zero grep hits). No claim of protocol-level support in either direction is supported by the reviewed evidence.

The allocation finding is shared. In the value-allocation dimension — this project's primary question — both protocols return the same answer: no allocation rule. A verbatim grep across the full AP2 documentation set (11 files plus README and CONTRIBUTING) finds no value-allocation primitive ("allocation", "revenue", "royalty": zero hits in allocation semantics; the only "split" hits refer to order splitting and phase splitting). The same holds for x402 (§2). AP2 does expose extension points that could host an allocation constraint type ("To define a new constraint, the following MUST be specified: - A uniquely defined type. - A Schema, including which fields are selectively disclosable. - The evaluation algorithm."), but none is defined in v0.2. The precise joint finding is therefore:
the authorization question has protocol designers; on the evidence we reviewed, the allocation question has none.

Evidence-insufficient items (stated, not hidden). AP2's governance sits with FIDO Alliance ("The core specification work will continue in FIDO" — docs/faq.md); the working groups' membership and admission criteria are not locatable in the repository and were not independently verified at snapshot date. AP2 deployment scale at the payment-instrument level is likewise not independently checkable from public sources we reviewed. We likewise cannot determine whether AP2 carries an official allocation roadmap or constraint proposal outside its repository; if one exists, this appendix's finding should be read alongside it.

6. Method & limitations

- Sources: x402.org (homepage, FAQ), the x402-foundation/x402 GitHub repository (README, main HEAD), docs.x402.org (facilitator page), the Coinbase Developer Platform x402 facilitator documentation (pricing) as of snapshot 2026-09-07; and at snapshot 2026-09-13: specs/x402-specification-v2.md, the three scheme specifications under specs/schemes/, all nine extensions under specs/extensions/, specs/transport-v2/a2a.md, TSC.md, ROADMAP.md, and the Technical Charter PDF — with the full repository tree enumerated (3,919 paths). For Appendix A: the AP2

repository's complete docs/ set (11 files), README, CONTRIBUTING, and the repository root tree, at main HEAD e1ea56db72a6385bce3e5c1112b3a56ce60acb43.

- Absence findings are scoped to reviewed material. The x402 specs/ tree contains network variants of the reviewed schemes that were not read line-by-line; if an allocation primitive exists there or elsewhere in the spec, this audit wants to know (open an issue).
- "ARL o" here applies to the **allocation dimension of the payment-execution layer**. It does not measure x402's execution-layer quality, security, or adoption, and it is not a cross-layer comparison with AP2 (see Appendix A).
- Evidence marked "insufficient" was not treated as absence. G4's residual is stated with its cause (charter-referenced governance repository not locatable in the reviewed tree). G2 is closed for the incumbent facilitator (public pricing) and open for the broader facilitator ecosystem.
- This methodology is versioned and itself expected to change; audits will be re-snapshotted against future protocol versions. Findings added after 2026-09-26 go into a v0.3 addendum, not into this document's body.

Corrections welcome: misquoted claims, wrong versions, or missed evidence — open an issue or PR with the spec reference. Corrections are merged with attribution.